

AI Governance Policy

1. Document Information

Policy Title: Artificial Intelligence Governance Policy

Policy Owner: Chief AI Officer / Chief Data Officer / Responsible AI Lead

Approved By: Executive Leadership Team

Applies To: All employees, contractors, vendors, partners, and business units using, developing, procuring, integrating, or managing AI systems

Effective Date: [Insert Date]

Review Frequency: At least annually or upon major regulatory, operational, or technology changes

Version: 1.0

2. Purpose

The purpose of this AI Governance Policy is to establish a clear, consistent, and responsible framework for the development, procurement, deployment, use, monitoring, and retirement of artificial intelligence systems across the organization.

This policy is designed to ensure that AI systems are used in a way that is ethical, secure, transparent, accountable, lawful, explainable where appropriate, aligned with business objectives, and respectful of human rights, privacy, fairness, and safety.

The organization recognizes that AI can improve productivity, decision-making, customer experience, innovation, automation, and operational efficiency. At the same time, AI can introduce risks such as bias, misinformation, privacy violations, security vulnerabilities, lack of transparency, overreliance, regulatory exposure, reputational harm, and unintended consequences.

This policy provides governance controls to maximize the benefits of AI while reducing risk.

3. Scope

This policy applies to all AI systems used by or on behalf of the organization, including but not limited to:

- Generative AI systems
- Machine learning models

- Predictive analytics systems
- Recommendation engines
- AI agents and autonomous workflows
- Chatbots and virtual assistants
- Computer vision systems
- Natural language processing systems
- Speech recognition and voice systems
- Robotic process automation enhanced by AI
- Third-party AI tools and APIs
- AI embedded in enterprise software platforms
- AI used for employee productivity, customer engagement, decision support, fraud detection, cybersecurity, marketing, HR, finance, legal, operations, product development, and software engineering

This policy applies whether the AI system is built internally, purchased from a vendor, accessed through a cloud service, integrated into an existing product, embedded in business software, or used informally by employees.

4. Policy Statement

The organization shall only use AI systems that are governed, risk-assessed, documented, monitored, and aligned with approved business purposes.

All AI systems must be designed, selected, deployed, and operated in accordance with the following principles:

1. **Human Accountability**
Humans remain responsible for decisions, actions, approvals, and outcomes involving AI systems.
2. **Fairness and Non-Discrimination**
AI systems must be assessed for unfair bias, discriminatory impact, and disproportionate harm.
3. **Transparency and Explainability**
Users, customers, employees, and affected individuals should be informed when AI is used in meaningful ways, especially when AI influences decisions or produces content.
4. **Privacy and Data Protection**
AI systems must comply with data protection requirements and must not use personal, confidential, or sensitive data without authorization.
5. **Security and Resilience**
AI systems must be protected against misuse, unauthorized access, data leakage, prompt injection, adversarial attacks, model manipulation, and system failure.

6. **Reliability and Accuracy**

AI systems must be tested and monitored to ensure they perform as intended within their approved use cases.

7. **Purpose Limitation**

AI systems must only be used for approved purposes and must not be repurposed without review.

8. **Responsible Innovation**

AI adoption should support business value while maintaining appropriate safeguards.

9. **Auditability and Traceability**

AI systems must maintain sufficient documentation, records, logs, and decision trails based on their risk level.

10. **Continuous Oversight**

AI governance is not a one-time approval process. AI systems must be monitored throughout their lifecycle.

5. Definitions

Artificial Intelligence System

An AI system is any software, model, tool, platform, or automated process that uses machine learning, statistical methods, generative models, natural language processing, computer vision, reasoning, optimization, or other computational techniques to generate outputs such as predictions, recommendations, classifications, content, decisions, summaries, actions, or insights.

Generative AI

Generative AI refers to AI systems that create new content, including text, images, audio, video, code, synthetic data, presentations, reports, or other outputs.

AI Agent

An AI agent is an AI system that can take actions, use tools, retrieve information, call APIs, interact with software, make plans, execute workflows, or perform multi-step tasks with varying levels of autonomy.

High-Risk AI

High-risk AI refers to AI systems that may materially affect people's rights, safety, employment, education, access to services, financial outcomes, legal standing, healthcare, critical infrastructure, or other significant areas of life or business.

Human-in-the-Loop

Human-in-the-loop means a qualified person actively reviews, validates, approves, or rejects AI-generated outputs before they are used for meaningful decisions or external actions.

Human-on-the-Loop

Human-on-the-loop means a qualified person supervises AI system behavior, reviews alerts, monitors outcomes, and can intervene when needed.

Model Owner

The individual or business function accountable for the AI system's purpose, performance, risk, documentation, controls, and lifecycle management.

AI Impact Assessment

A structured review used to evaluate the risks, benefits, intended use, data, fairness, privacy, security, compliance, and human oversight requirements of an AI system.

6. Governance Objectives

The organization's AI governance program shall pursue the following objectives:

- Enable responsible AI innovation
 - Protect customers, employees, partners, and affected individuals
 - Ensure AI use aligns with laws, regulations, contracts, and internal standards
 - Reduce operational, legal, ethical, security, privacy, and reputational risks
 - Establish clear ownership and accountability
 - Maintain an inventory of AI systems
 - Ensure high-risk AI systems receive appropriate review and approval
 - Promote transparency and trust
 - Prevent unauthorized use of sensitive data
 - Define acceptable and prohibited AI uses
 - Support auditability, monitoring, and continuous improvement
-

7. AI Governance Structure

7.1 AI Governance Committee

The organization shall establish an AI Governance Committee responsible for overseeing AI strategy, risk, policy, compliance, and lifecycle controls.

The committee should include representatives from:

- Executive leadership
- Legal
- Compliance
- Information security
- Privacy
- Data governance
- Technology
- Risk management
- Human resources
- Business operations
- Product or customer experience
- Internal audit
- Responsible AI or ethics function

7.2 Responsibilities of the AI Governance Committee

The AI Governance Committee shall:

- Approve this policy and related standards
- Review high-risk AI use cases
- Maintain the AI risk classification framework
- Approve or reject high-risk AI deployments
- Review AI incidents and corrective actions
- Ensure compliance with applicable regulations
- Monitor organization-wide AI adoption
- Review vendor and third-party AI risk
- Oversee AI training and awareness
- Ensure AI systems are periodically reviewed
- Escalate significant risks to executive leadership

7.3 AI System Owners

Each AI system must have a designated AI System Owner.

The AI System Owner is responsible for:

- Defining the business purpose of the AI system
- Ensuring proper documentation

- Completing the AI intake process
- Conducting risk assessments
- Ensuring required approvals are obtained
- Monitoring system performance
- Maintaining human oversight controls
- Reporting incidents
- Ensuring users are trained
- Coordinating with legal, security, privacy, and compliance teams
- Retiring the system when it is no longer appropriate or approved

7.4 Technology and Data Teams

Technology and data teams are responsible for:

- Technical design and implementation
- Data quality and data lineage
- Model development and validation
- Security controls
- System integration
- Logging and monitoring
- Access controls
- Testing and evaluation
- Technical documentation
- Change management

7.5 Legal, Privacy, and Compliance Teams

Legal, privacy, and compliance teams are responsible for:

- Reviewing regulatory obligations
- Assessing privacy and data protection risks
- Reviewing contracts and vendor terms
- Evaluating intellectual property concerns
- Reviewing customer, employee, or public-facing disclosures
- Advising on high-risk or restricted uses
- Supporting incident response

7.6 Employees and End Users

Employees and authorized users are responsible for:

- Using AI only for approved business purposes
- Following data handling rules
- Verifying AI outputs before relying on them
- Not submitting sensitive data into unauthorized AI tools

- Reporting AI errors, risks, misuse, or suspicious behavior
 - Completing required AI training
 - Avoiding overreliance on AI-generated outputs
-

8. AI System Inventory

The organization shall maintain a centralized inventory of all AI systems.

The AI inventory shall include, at minimum:

- System name
- Business owner
- Technical owner
- Vendor or provider, if applicable
- Business purpose
- Intended users
- Affected individuals or groups
- AI capabilities used
- Data sources
- Data classification
- Risk classification
- Deployment environment
- Human oversight model
- Approval status
- Date approved
- Review date
- Key controls
- Monitoring requirements
- Incident history
- Retirement date, if applicable

No AI system may be used in production unless it is recorded in the AI inventory and assigned an owner.

9. AI Use Case Intake and Approval

Before an AI system is developed, purchased, integrated, or deployed, the AI System Owner must complete an AI Use Case Intake Form.

The intake process shall document:

- Business problem or opportunity
- Intended AI capability
- Expected benefits
- Users and stakeholders
- Data involved
- Personal or sensitive data usage
- Customer or employee impact
- Decision-making impact
- Level of autonomy
- Vendor involvement
- Regulatory considerations
- Security risks
- Privacy risks
- Bias and fairness risks
- Human oversight requirements
- Monitoring plan
- Rollback or fallback plan

AI use cases must be reviewed and approved based on their risk classification.

10. AI Risk Classification

All AI systems shall be classified into one of the following risk levels.

10.1 Low-Risk AI

Low-risk AI systems have minimal impact on individuals, business operations, legal obligations, or sensitive data.

Examples may include:

- Internal brainstorming support
- Drafting non-sensitive internal content
- Summarizing public information
- Grammar correction
- Basic productivity support
- Internal knowledge search with approved data

Minimum controls:

- Approved tool usage
- User training
- Data handling restrictions

- Basic output verification

10.2 Moderate-Risk AI

Moderate-risk AI systems support business processes but do not make final decisions about individuals or critical outcomes.

Examples may include:

- Customer support draft responses
- Sales lead prioritization
- Internal analytics
- Marketing content generation
- Code generation with human review
- Business reporting support
- Document classification

Minimum controls:

- AI inventory registration
- Use case intake
- Data review
- Security review
- Human review of outputs
- Monitoring
- Periodic reassessment

10.3 High-Risk AI

High-risk AI systems can materially affect individuals, rights, safety, finances, employment, access to services, legal outcomes, or critical operations.

Examples may include:

- Hiring, promotion, or termination decision support
- Credit, lending, insurance, or financial eligibility support
- Healthcare decision support
- Legal decision support
- Safety-critical operations
- Biometric identification
- Critical infrastructure support
- Fraud detection systems that affect account access
- AI systems used in education assessment
- AI systems used for employee monitoring or performance scoring

Minimum controls:

- Formal AI Impact Assessment
- Legal review
- Privacy review
- Security review
- Bias and fairness assessment
- Human-in-the-loop approval
- Explainability assessment
- Robust documentation
- Pre-deployment validation
- Executive or AI Governance Committee approval
- Ongoing monitoring
- Incident response plan
- Periodic independent review

10.4 Prohibited or Restricted AI

Certain AI uses are prohibited or require explicit executive approval.

Prohibited uses include:

- AI systems designed to manipulate, deceive, or exploit vulnerable individuals
- AI systems used for unlawful discrimination
- Unauthorized surveillance
- Unauthorized biometric identification
- Social scoring of individuals
- Use of confidential, personal, regulated, or sensitive data in unauthorized public AI tools
- AI-generated impersonation without disclosure
- AI-generated deepfakes without authorization and clear labeling
- Fully automated decisions with significant impact without required human review
- AI use that violates laws, contracts, privacy commitments, or internal policy
- AI systems that intentionally bypass security, compliance, or access controls
- Use of AI to generate malicious code, phishing, fraud, harassment, or harmful content

Restricted uses require AI Governance Committee review before use.

11. Data Governance Requirements

AI systems must comply with the organization's data governance, privacy, security, and records management policies.

11.1 Data Authorization

Only approved data may be used in AI systems.

Before using data in an AI system, the AI System Owner must confirm:

- The organization has the right to use the data
- The data is appropriate for the intended purpose
- Personal data is handled lawfully
- Sensitive data is protected
- Contractual restrictions are respected
- Data retention rules are followed
- Data sharing restrictions are understood
- Data minimization has been applied

11.2 Sensitive Data

Sensitive data must not be entered into public or unauthorized AI tools.

Sensitive data includes:

- Personal information
- Health information
- Financial information
- Employee records
- Customer records
- Trade secrets
- Source code
- Legal documents
- Security credentials
- Authentication tokens
- Confidential strategy documents
- Regulated data
- Proprietary business information

Sensitive data may only be used in approved AI systems with appropriate security, privacy, access control, and contractual safeguards.

11.3 Data Quality

AI systems must use data that is fit for purpose.

Data quality considerations include:

- Accuracy

- Completeness
- Timeliness
- Relevance
- Representativeness
- Bias
- Provenance
- Lineage
- Consistency
- Labeling quality
- Data drift

High-risk AI systems must include documented data quality reviews.

11.4 Data Minimization

AI systems should use the minimum amount of data necessary to achieve the approved purpose.

Unnecessary personal, sensitive, confidential, or regulated data must be excluded where possible.

11.5 Training Data

For internally trained or fine-tuned models, the organization must document:

- Data sources
- Data ownership
- Data permissions
- Data preprocessing steps
- Data exclusions
- Known limitations
- Bias risks
- Retention period
- Security controls

12. Privacy Requirements

AI systems must be designed and operated in accordance with applicable privacy obligations.

Privacy reviews are required when AI systems:

- Process personal data
- Infer characteristics about individuals
- Monitor behavior

- Profile individuals
- Use customer or employee data
- Use biometric, health, financial, or other sensitive data
- Make or support decisions about individuals
- Share data with third-party AI providers

Privacy controls may include:

- Privacy impact assessments
- Consent where required
- Notice and disclosure
- Data minimization
- De-identification or anonymization
- Access controls
- Retention limits
- Vendor privacy review
- Cross-border data transfer review
- Individual rights processes
- Human review for significant decisions

13. Security Requirements

AI systems must be protected through appropriate technical, administrative, and operational controls.

Security controls may include:

- Identity and access management
- Role-based access controls
- Least privilege access
- Encryption in transit and at rest
- Secure API management
- Logging and monitoring
- Secrets management
- Vulnerability scanning
- Threat modeling
- Secure software development practices
- Network segmentation
- Data loss prevention
- Backup and recovery
- Incident response procedures
- Vendor security review

13.1 AI-Specific Security Risks

AI systems must be evaluated for AI-specific threats, including:

- Prompt injection
- Jailbreak attempts
- Data poisoning
- Model inversion
- Model extraction
- Training data leakage
- Hallucinated outputs
- Unauthorized tool use
- Malicious plugin or connector access
- Agentic workflow abuse
- Adversarial inputs
- Output manipulation
- Excessive autonomy
- Supply chain risks
- Untrusted third-party models

High-risk AI systems and AI agents must undergo additional security testing before production deployment.

14. Generative AI Usage Requirements

Generative AI may be used only in accordance with approved business rules.

14.1 Acceptable Generative AI Uses

Acceptable uses may include:

- Drafting internal communications
- Summarizing approved documents
- Creating training materials
- Brainstorming ideas
- Generating code with human review
- Creating marketing drafts with approval
- Supporting customer service agents
- Searching internal knowledge bases
- Translating non-sensitive content
- Improving productivity workflows

14.2 Generative AI Output Review

Users must review and validate AI-generated outputs before use.

AI outputs must be checked for:

- Accuracy
- Completeness
- Bias
- Confidentiality
- Intellectual property concerns
- Privacy concerns
- Tone and brand alignment
- Legal or regulatory implications
- Security risks
- Fabricated references or facts

Generative AI outputs must not be treated as authoritative unless independently verified.

14.3 AI-Generated Content Disclosure

The organization shall disclose AI-generated or AI-assisted content when required by law, policy, contract, platform rules, or reasonable stakeholder expectations.

Disclosure is especially important when AI-generated content is:

- Customer-facing
- Public-facing
- Used in legal, financial, healthcare, employment, or regulatory contexts
- Used to represent a person
- Used to generate synthetic media
- Used in decision-making communications

14.4 Prohibited Generative AI Uses

Employees must not use generative AI to:

- Create deceptive content
- Impersonate another person without authorization
- Generate harmful, abusive, fraudulent, or illegal content
- Produce malware or phishing content
- Bypass security controls
- Submit confidential data to unauthorized tools
- Make final decisions about individuals without human review
- Generate legal, medical, financial, or compliance advice without qualified review

- Create public claims without verification
-

15. AI Agents and Autonomous Systems

AI agents require additional governance because they may take actions, use tools, access systems, and execute workflows.

15.1 Agent Approval

AI agents must be reviewed before deployment if they can:

- Send emails or messages
- Access customer data
- Modify records
- Trigger transactions
- Call APIs
- Execute code
- Search external websites
- Use internal tools
- Interact with production systems
- Make recommendations that influence decisions
- Operate without real-time human approval

15.2 Agent Control Requirements

AI agents must include appropriate controls, such as:

- Clear task boundaries
- Approved tool access
- Least privilege permissions
- Human approval for sensitive actions
- Action logging
- Rate limits
- Cost controls
- Error handling
- Escalation paths
- Kill switch or disable function
- Rollback plan
- Monitoring dashboard
- Guardrails for restricted actions

15.3 Agent Prohibited Actions

AI agents must not be allowed to:

- Access unauthorized systems
 - Make financial transactions without approval
 - Delete production data without approval
 - Send external communications without safeguards
 - Make employment, legal, medical, financial, or eligibility decisions without qualified human review
 - Circumvent access controls
 - Modify security settings
 - Execute unapproved code in production
 - Use tools beyond their approved purpose
-

16. Human Oversight

AI systems must include human oversight appropriate to their risk level.

16.1 Human Review Requirements

Human review is required when AI outputs are used for:

- Employment decisions
- Customer eligibility decisions
- Financial decisions
- Healthcare decisions
- Legal decisions
- Safety-related operations
- Disciplinary actions
- Regulatory submissions
- Public statements
- High-impact customer communications

16.2 Human Reviewer Qualifications

Human reviewers must:

- Understand the AI system's purpose
- Understand known limitations
- Be trained to identify errors and bias
- Have authority to override AI outputs
- Not rely blindly on AI recommendations
- Document overrides where required

- Escalate concerns

16.3 Automation Limits

AI systems must not be granted full autonomy for high-impact decisions unless explicitly approved by the AI Governance Committee and permitted by applicable law.

17. Fairness, Bias, and Non-Discrimination

AI systems must be evaluated for fairness risks when they affect individuals, groups, customers, employees, or communities.

Fairness reviews may include:

- Identifying affected groups
- Reviewing training data representativeness
- Testing model performance across groups
- Evaluating disparate impact
- Reviewing proxy variables
- Assessing accessibility
- Reviewing feedback and complaints
- Monitoring outcomes over time

High-risk AI systems must document fairness testing before deployment and periodically after deployment.

If unfair bias or discriminatory outcomes are detected, the system must be remediated, restricted, suspended, or retired.

18. Explainability and Transparency

AI systems must provide an appropriate level of explanation based on their risk and use.

Transparency requirements may include:

- Informing users that AI is being used
- Explaining the purpose of the AI system
- Describing the type of data used
- Explaining the role of human review
- Providing limitations of the system

- Explaining how outputs should and should not be used
- Providing appeal or review mechanisms for significant decisions
- Labeling AI-generated content when appropriate

High-risk AI systems must provide documentation sufficient for internal review, audit, and stakeholder understanding.

19. Model Development and Validation

Internally developed AI models must follow approved development standards.

19.1 Development Requirements

Development teams must document:

- Business objective
- Model type
- Training data
- Feature selection
- Data preprocessing
- Model assumptions
- Evaluation metrics
- Known limitations
- Testing results
- Bias assessment
- Security controls
- Deployment plan
- Monitoring plan

19.2 Validation Requirements

Before deployment, AI systems must be validated for:

- Accuracy
- Reliability
- Robustness
- Bias
- Privacy risks
- Security risks
- Explainability
- Performance under expected conditions
- Failure modes

- Misuse scenarios
- Human oversight effectiveness

High-risk AI systems must not be deployed until validation is complete and documented.

20. Procurement and Third-Party AI

AI tools or systems purchased from vendors must undergo review before use.

Vendor review may include:

- Security assessment
- Privacy assessment
- Legal and contract review
- Data usage review
- Model transparency review
- Subprocessor review
- Regulatory compliance review
- Intellectual property review
- Availability and resilience review
- Exit strategy review
- Audit rights
- Incident notification obligations
- Data retention and deletion terms

20.1 Vendor Requirements

Vendors should provide, where appropriate:

- Documentation of AI capabilities
- Intended use and limitations
- Data handling practices
- Security controls
- Privacy controls
- Model evaluation results
- Bias testing information
- Human oversight guidance
- Incident reporting process
- Compliance certifications
- Service-level commitments
- Change notification procedures

The organization must not use third-party AI tools that fail to meet required governance, security, privacy, or legal standards.

21. Intellectual Property and Copyright

AI systems must be used in a way that respects intellectual property rights.

Employees must not:

- Submit proprietary code, confidential documents, trade secrets, or copyrighted materials into unauthorized AI tools
- Use AI-generated content without reviewing ownership, licensing, and usage rights
- Publish AI-generated content that may infringe third-party rights
- Represent AI-generated work as wholly human-created where disclosure is required
- Use AI to imitate protected brands, artists, individuals, or copyrighted styles in a way that creates legal risk

Legal review is required for high-value, public-facing, commercial, or externally distributed AI-generated content when intellectual property risk is material.

22. AI in Employment and HR

AI systems used in employment-related contexts require heightened review.

Employment-related AI includes systems used for:

- Recruiting
- Resume screening
- Candidate ranking
- Interview analysis
- Promotion recommendations
- Performance evaluation
- Workforce monitoring
- Compensation analysis
- Termination support
- Training recommendations

Such systems require:

- Legal review

- Bias assessment
- Human oversight
- Documentation
- Transparency where required
- Vendor review, if applicable
- Periodic monitoring
- Appeal or review process where appropriate

AI must not be the sole basis for employment decisions unless explicitly approved and legally permissible.

23. AI in Customer-Facing Use Cases

Customer-facing AI systems must be designed to protect trust, safety, privacy, and service quality.

Customer-facing AI must:

- Clearly identify when users are interacting with AI where appropriate
- Provide escalation to a human when needed
- Avoid misleading customers
- Avoid making unsupported claims
- Protect customer data
- Maintain records of significant interactions where required
- Be monitored for quality, safety, and fairness
- Include controls to prevent harmful or inappropriate responses

AI-generated customer communications must be reviewed or controlled according to risk level.

24. AI in Software Development

AI coding assistants may be used only in accordance with approved software development and security standards.

Developers using AI-generated code must:

- Review all generated code
- Test code before use
- Check for security vulnerabilities
- Validate licensing and IP concerns

- Avoid submitting sensitive source code to unauthorized tools
- Avoid using AI-generated code without understanding it
- Follow secure coding practices
- Ensure generated dependencies are approved
- Document material AI-assisted development where required

AI-generated code must not be deployed to production without standard review, testing, and approval.

25. Monitoring and Ongoing Review

AI systems must be monitored after deployment based on their risk level.

Monitoring may include:

- Accuracy
- Performance drift
- Data drift
- Bias drift
- User feedback
- Complaints
- Security events
- Unexpected outputs
- System downtime
- Cost anomalies
- Tool usage
- Human override rates
- Incident reports
- Regulatory changes
- Vendor changes

High-risk AI systems must be reviewed at least annually, or more frequently if required.

AI systems must be reassessed when:

- The use case changes
- Data sources change
- The model changes
- The vendor changes
- The system is integrated into new workflows
- The user population changes
- The regulatory environment changes
- Incidents occur

- Performance degrades
-

26. AI Incident Management

An AI incident is any event involving an AI system that causes or may cause harm, error, policy violation, security issue, privacy issue, regulatory issue, reputational damage, or unintended business impact.

Examples of AI incidents include:

- Biased or discriminatory output
- Disclosure of confidential data
- Incorrect high-impact recommendation
- Unauthorized AI tool use
- Harmful customer interaction
- Prompt injection attack
- Model producing unsafe outputs
- AI agent taking unauthorized action
- Security breach involving AI
- Vendor AI failure
- Regulatory complaint
- Public misinformation caused by AI-generated content

26.1 Incident Reporting

Employees must promptly report suspected AI incidents to the appropriate internal channel.

Reports should include:

- System involved
- Description of issue
- Date and time
- Affected users or individuals
- Data involved
- Business impact
- Screenshots or logs, if available
- Immediate actions taken

26.2 Incident Response

The organization shall investigate AI incidents and take corrective action.

Corrective actions may include:

- Disabling the AI system
- Rolling back a model
- Removing access
- Notifying affected parties
- Notifying regulators where required
- Correcting outputs
- Updating training data
- Revising prompts or guardrails
- Strengthening security controls
- Updating vendor terms
- Retraining users
- Updating this policy

High-severity AI incidents must be escalated to executive leadership and the AI Governance Committee.

27. Documentation and Recordkeeping

AI systems must maintain documentation appropriate to their risk level.

Documentation may include:

- Use case intake form
- AI impact assessment
- Risk classification
- Data sources
- Model documentation
- Vendor documentation
- Testing results
- Bias assessment
- Privacy review
- Security review
- Approval records
- Human oversight procedures
- Monitoring logs
- Incident records
- Change history
- Retirement records

High-risk AI systems must maintain documentation sufficient for audit, regulatory review, and internal accountability.

28. Training and Awareness

The organization shall provide AI training appropriate to employee roles.

Training may include:

- Responsible AI principles
- Approved and prohibited AI uses
- Data privacy and confidentiality
- Generative AI limitations
- Bias and fairness
- Security risks
- Prompt injection and AI-specific threats
- Human review responsibilities
- AI incident reporting
- Vendor AI risks
- Role-specific AI procedures

Employees must complete required AI training before using approved AI systems where training is mandated.

29. Change Management

Material changes to AI systems must follow change management procedures.

Material changes include:

- New model version
- New vendor
- New data source
- New use case
- Expanded user group
- Change in autonomy level
- New integration
- New external-facing use
- Change affecting risk classification
- Significant performance change
- New legal or regulatory requirement

High-risk AI systems require review and approval before material changes are deployed.

30. Exceptions

Exceptions to this policy must be documented, justified, time-bound, and approved by the AI Governance Committee or designated authority.

Exception requests must include:

- Policy requirement requiring exception
- Business justification
- Risk assessment
- Compensating controls
- Duration of exception
- Responsible owner
- Review date
- Approval record

Exceptions may be denied, modified, revoked, or escalated based on risk.

31. Compliance and Enforcement

Failure to comply with this policy may result in corrective action, including:

- Removal of AI system access
- Suspension of AI system use
- Mandatory retraining
- Disciplinary action
- Contractual remedies for vendors
- Escalation to legal, compliance, HR, or executive leadership

Intentional misuse of AI systems, unauthorized disclosure of confidential data, unlawful discrimination, security violations, or attempts to bypass controls may result in severe disciplinary or legal action.

32. Policy Review

This policy shall be reviewed at least annually and updated as needed based on:

- Changes in law or regulation
- Changes in AI technology
- Internal audit findings
- AI incidents
- Vendor changes
- Business strategy changes
- Industry best practices
- Regulatory guidance
- Stakeholder feedback

The AI Governance Committee is responsible for ensuring this policy remains current and effective.

Appendix A: AI Use Case Intake Form

Basic Information

- Use case name:
- Business unit:
- Business owner:
- Technical owner:
- Date submitted:
- Target launch date:
- Internal or external use:
- Vendor or internal build:

Business Purpose

- What problem does this AI system solve?
- What business outcome is expected?
- Who will use the system?
- Who may be affected by the system?
- What decisions or actions will the system support?

AI Capabilities

- Type of AI system:
- Generative AI involved:
- Predictive model involved:
- AI agent involved:
- Autonomous actions involved:
- External tools or APIs involved:

Data

- Data sources:
- Personal data involved:
- Sensitive data involved:
- Confidential data involved:
- Data retention requirements:
- Data sharing requirements:
- Data quality concerns:

Risk

- Could this affect individuals?
- Could this affect employment, finance, healthcare, education, legal rights, safety, or access to services?
- Could this create bias or discrimination risk?
- Could this create security risk?
- Could this create privacy risk?
- Could this create reputational risk?
- Could this create regulatory risk?

Oversight

- Human review required:
- Human approval required:
- Escalation path:
- Override process:
- Monitoring process:

Approval

- Risk classification:
- Required reviews:
- Approved by:
- Approval date:
- Conditions of approval:

Appendix B: AI Risk Assessment Checklist

For each AI system, assess the following:

Business Risk

- Is the purpose clearly defined?
- Is the use case aligned with business strategy?
- Is there a measurable benefit?
- Is there a fallback plan if the system fails?

Legal and Regulatory Risk

- Are applicable laws identified?
- Are industry-specific requirements considered?
- Are customer or contractual commitments affected?
- Is legal review required?

Privacy Risk

- Does the system use personal data?
- Is sensitive data involved?
- Is consent or notice required?
- Is data minimized?
- Are retention rules defined?

Security Risk

- Is access controlled?
- Is data encrypted?
- Are APIs secured?
- Is logging enabled?
- Has threat modeling been completed?
- Are AI-specific attacks considered?

Fairness Risk

- Could outputs affect protected or vulnerable groups?
- Has bias testing been performed?
- Are proxy variables present?
- Are outcomes monitored?

Transparency Risk

- Will users know AI is being used?
- Are explanations available?
- Are limitations disclosed?

- Is AI-generated content labeled where needed?

Operational Risk

- Has the system been tested?
- Is there a monitoring plan?
- Is there an incident response plan?
- Is there a rollback plan?
- Are owners assigned?

Appendix C: AI System Approval Workflow

1. Submit AI Use Case Intake Form
2. Assign AI System Owner
3. Classify AI risk level
4. Complete required assessments
5. Conduct privacy review if needed
6. Conduct security review if needed
7. Conduct legal review if needed
8. Conduct bias and fairness review if needed
9. Conduct vendor review if needed
10. Define human oversight controls
11. Define monitoring and incident process
12. Submit for approval
13. Record system in AI inventory
14. Deploy only after approval
15. Monitor system performance
16. Review periodically
17. Retire or update when appropriate

Appendix D: Minimum Controls by Risk Level

Control	Low Risk	Moderate Risk	High Risk
AI inventory entry	Recommended	Required	Required
Use case intake	Recommended	Required	Required
Business owner	Required	Required	Required
Data review	Basic	Required	Required

Control	Low Risk	Moderate Risk	High Risk
Privacy review	If needed	If needed	Required if personal data involved
Security review	Basic	Required	Required
Legal review	If needed	If needed	Required
Bias assessment	Not usually required	If people are affected	Required
Human oversight	User review	Human review	Human-in-the-loop
Monitoring	Basic	Periodic	Continuous or scheduled
Incident process	Required	Required	Required
Executive approval	Not required	Sometimes	Required
Periodic review	Annual or as needed	Annual	At least annual or more frequent

Appendix E: AI System Card Template

System Overview

- System name:
- Owner:
- Purpose:
- Users:
- Vendor:
- Deployment date:
- Risk level:

Intended Use

- Approved uses:
- Prohibited uses:
- User groups:
- Affected stakeholders:

Data

- Data sources:
- Data classification:
- Personal data:
- Sensitive data:
- Data limitations:

Model/System Details

- Model type:
- Version:
- Training/fine-tuning information:
- Evaluation metrics:
- Known limitations:

Human Oversight

- Review process:
- Override process:
- Escalation process:

Risk and Controls

- Key risks:
- Mitigation controls:
- Security controls:
- Privacy controls:
- Fairness controls:

Monitoring

- Metrics monitored:
- Review frequency:
- Incident triggers:
- Owner of monitoring:

Approval

- Approved by:
- Date:
- Conditions:
- Next review date:

Appendix F: Employee AI Usage Rules

Employees must follow these rules when using AI:

1. Use only approved AI tools for business work.

2. Do not enter confidential, personal, regulated, or sensitive data into unauthorized AI systems.
 3. Review AI outputs before relying on them.
 4. Verify facts, numbers, citations, legal claims, technical claims, and customer-facing content.
 5. Do not use AI to make final high-impact decisions without required human approval.
 6. Do not use AI to impersonate others or create deceptive content.
 7. Do not use AI to bypass security, privacy, compliance, or access controls.
 8. Report harmful, biased, inaccurate, or suspicious AI behavior.
 9. Follow copyright, confidentiality, and data protection requirements.
 10. Ask the AI Governance Committee, Legal, Privacy, Security, or Compliance team when unsure.
-

Appendix G: AI Incident Severity Levels

Low Severity

Minor issue with limited impact.

Examples:

- Inaccurate internal draft
- Minor chatbot error
- Low-risk hallucination caught before use

Response:

- Correct issue
- Notify system owner
- Document if recurring

Medium Severity

Issue affects business process, customer experience, or internal decision support.

Examples:

- Incorrect customer response
- Repeated biased outputs
- System performance degradation
- Unauthorized internal AI use

Response:

- Notify system owner
- Investigate root cause
- Apply corrective action
- Report to governance team

High Severity

Issue may affect individuals, legal obligations, sensitive data, security, or reputation.

Examples:

- Confidential data leakage
- Discriminatory decision support
- Unauthorized agent action
- Security compromise
- Public-facing harmful output
- Regulatory complaint

Response:

- Escalate immediately
- Disable or restrict system if needed
- Notify legal, compliance, privacy, and security
- Conduct formal investigation
- Document corrective actions
- Notify affected parties or regulators where required

Appendix H: AI Governance Metrics

The organization may track the following AI governance metrics:

- Number of AI systems in inventory
- Number of approved AI use cases
- Number of rejected or paused AI use cases
- Number of high-risk AI systems
- Number of AI incidents
- Incident severity and resolution time
- Percentage of AI systems with assigned owners
- Percentage of AI systems reviewed on schedule
- Number of employees trained
- Number of vendor AI reviews completed

- Number of systems with documented human oversight
 - Bias testing completion rate
 - Security review completion rate
 - Privacy review completion rate
 - Monitoring coverage by risk level
 - Model drift or performance degradation events
 - Human override rates
 - Customer complaints related to AI
-

Appendix I: AI Governance Review Questions for Leadership

Leadership should periodically ask:

1. Do we know where AI is being used across the organization?
 2. Do all AI systems have owners?
 3. Are high-risk AI systems reviewed before deployment?
 4. Are employees using unauthorized AI tools?
 5. Are we protecting sensitive and confidential data?
 6. Are AI systems aligned with business value?
 7. Are we monitoring AI systems after deployment?
 8. Are humans accountable for AI-supported decisions?
 9. Are our vendors meeting AI governance expectations?
 10. Are we prepared to respond to AI incidents?
 11. Are we complying with applicable laws and regulations?
 12. Are we building trust with customers, employees, and stakeholders?
-

33. Final Policy Acknowledgment

All employees, contractors, and authorized users must comply with this AI Governance Policy. By using AI systems on behalf of the organization, users acknowledge their responsibility to use AI lawfully, ethically, securely, transparently, and in alignment with approved business purposes.

The organization reserves the right to monitor AI system usage, restrict access, require additional approvals, update this policy, and take corrective action when AI systems are misused or create unacceptable risk.